

Ganatri Enhancement Report

Code review covering **5 critical, 10 major, and 10 minor findings** across security, code quality, performance, and UX.

Executive Summary. A targeted audit of the Ganatri multiplayer card-game codebase identified 25 findings across security, code quality, missing UX guards, and performance. Five issues are rated Critical and require immediate attention before any production deployment: an open admin secret default, an unguarded WebRTC relay, an admin-engine player-count mismatch, a session token leaked in the OAuth redirect URL, and unvalidated move payloads that allow large-array denial-of-service. Ten Major findings cover insecure randomness, memory leaks, stale React closures, and redundant engine invocations. Ten Minor findings include two dependency CVEs, a bundle-size warning, and several low-risk UX papercuts. Addressing the top-10 prioritised actions (listed at the end of this report) will eliminate all Critical and High risks and substantially harden the application for public use.

5 Critical findings must be resolved before any public-facing deployment. The open admin default (C1), unguarded voice relay (C2), and session token in the redirect URL (C4) each represent exploitable vulnerabilities with no mitigating controls in the current codebase.

SECURITY

Critical & High-Severity Vulnerabilities

C1 Admin secret defaults to open — any socket becomes admin **CRITICAL**

packages/server/src/config.ts:103-106

When `ADMIN_SECRET` is not set (the default in any deployment that forgets the env var), any WebSocket client can authenticate as admin and call `ADMIN_UPDATE_CONFIG`, `ADMIN_GET_STATS`, and the export endpoint. There is no other check gate.

Recommendation: Default to a secure mode — if `ADMIN_SECRET` is unset, return `false` and log a startup warning. Require an explicit `ADMIN_SECRET=` set to the empty string for intentional dev openness.

C2 Voice signaling relay has no room membership check **CRITICAL**

packages/server/src/handlers.ts:1065-1102

Any authenticated player in any room can send `VOICE_OFFER`, `VOICE_ANSWER`, `VOICE_ICE`, or `VOICE_RENEGOTIATE` to any other player's socket by guessing their `targetPlayerId`. Player IDs appear in `STATE_UPDATE` and `ROOM_UPDATE` payloads.

Recommendation: Before relaying, verify that both the sender and `targetPlayerId` are members of the same active room (`session.roomCode === targetSession.roomCode && room.phase === 'PLAYING'`).

C4 OAuth callback appends `auth_token` in redirect URL **CRITICAL**

packages/server/src/createApp.ts:320-326

The session token appears in the browser URL bar, browser history, and `Referer` headers on subsequent cross-origin requests, and is logged by any reverse proxy or CDN — a standard OAuth anti-pattern when an `httpOnly` cookie is simultaneously issued.

Recommendation: Remove the URL query-parameter path. For cross-origin scenarios, configure the cookie with `SameSite=None; Secure`, or implement a short-lived one-time code exchange (valid ≤ 30 seconds) rather than embedding the 30-day session token.

C5 `isMakeMovePayload` does not validate card ID format or capture array length

CRITICAL

packages/server/src/handlers.ts:2499-2513

The validator accepts any non-empty string for `card` and any array of strings for `capture` — no format check, no length bound. A 10,000-element `capture` array passes validation and reaches `applyMove` before being rejected, enabling a payload-based DoS.

Recommendation: Add regex validation (`/^(10|[2-9JQKA])[SHDC]$/`) per card string, `capture.length` at 13, and add a 4-character max string length check.

N4 drizzle-orm SQL injection CVE (GHSA-gpj5-g38j-94v9) **HIGH — CVE**

packages/db/package.json

`npm audit` reports a high-severity SQL injection vulnerability in `drizzle-orm < 0.45.2` via improperly escaped SQL identifiers. Affects all DB-backed deployments.

Recommendation: Upgrade `drizzle-orm` to `^0.45.2` and run the `drizzle-kit` migration check afterwards.

M2 Room code generated with `Math.random()` — not cryptographically random

HIGH

packages/server/src/handlers.ts:2480-2488

V8's `Math.random()` has roughly a 32-bit state, far weaker than the $34^6 \approx 1.5$ billion possible room codes. An attacker who seeds or observes the PRNG state could predict upcoming room codes and join rooms uninvited.

Recommendation: Use `crypto.randomInt(0, ROOM_CODE_CHARS.length)` per character (Node 14.10+, no additional import).

M10 No HTTP security headers on server responses MEDIUM

packages/server/src/createApp.ts

No `Content-Security-Policy`, `X-Frame-Options`, `X-Content-Type-Options`, `Referrer-Policy`, or `Strict-Transport-Security` headers are set. The OAuth callback and asset endpoints are unprotected against clickjacking and MIME-type sniffing.

Recommendation: Add a security-headers middleware (or use `helmet`) before all route handlers. Minimum: `X-Frame-Options: DENY`, `X-Content-Type-Options: nosniff`, `Referrer-Policy: strict-origin-when-cross-origin`.

N1 `auth_token` written to both `sessionStorage` and `localStorage` LOW

packages/web/src/net/socket.ts:71-80

After OAuth redirect, the token is stored in `localStorage` (30-day persistence) in addition to `sessionStorage`. Combined with C4, any XSS could exfiltrate the long-lived token from `localStorage`.

Recommendation: Remove the `localStorage.setItem(LEGACY_TOKEN_KEY, authToken)` line in `captureAuthTokenFromUrl`; use `sessionStorage` only.

CODE QUALITY

Logic Errors & Structural Issues

C3 Admin `maxPlayers` allows 5-8 but engine hard-errors above 4 CRITICAL

packages/server/src/handlers.ts:972 vs packages/engine/src/game.ts:46

The admin socket allows setting `maxPlayers` to any value 2-8. However, `createGame` throws `'Ganatri requires 2-4 players'` for any value above 4. If an admin sets `maxPlayers = 6`, six players can enter the room but `handleStartGame` crashes, leaving room state inconsistent.

Recommendation: Change the upper bound in `isValidPlayers` to `<= 4` to match the engine's hard constraint.

M7 `useEffect` in `Part2Board` suppresses lint and has stale closure risk

MEDIUM

packages/web/src/components/Part2Board.tsx:58-68

An `eslint-disable-next-line react-hooks/exhaustive-deps` hides a real problem: `legalIds` is derived from `view.hand` and `view.trick`, but `view` is not in the dependency array. If `view.hand` changes without `view.ledSuit` changing, the effect does not re-run and `onSelectionChange` is called with a stale `legalIds` set, causing incorrect card highlights.

Recommendation: Remove the `eslint-disable` and add `legalIds` (or compute it inline with `view` in deps) and `play` to the dependency array. Wrap `play` in `useCallback` with correct deps.

M8 `GameProvider` `useMemo` context rebuilt on every state change **MEDIUM**

packages/web/src/state/GameProvider.tsx:529-577

The `useMemo` producing the context value has 30+ dependencies. Every state change — connected, session, view, room, lastEvent — causes the entire context object to be rebuilt and all consumers to re-render, even those that only call stable callbacks like `makeMove`.

Recommendation: Split into at least two contexts: a "game state" context and an "actions" context. The actions context can be memoized once at mount.

M9 `handleStartGame` allows restart without clearing previous-game timers

MEDIUM

packages/server/src/handlers.ts:1541-1583

When restarting from `DONE`, the handler resets `room.completedAt` but does not clear `room.disconnectedAt`, `room.gracePeriodTimers`, or running timers from the previous game. A stale grace-period timer could fire on the new game's room and auto-forfeit a player who is present.

Recommendation: At the top of the restart path, call `clearTurnTimer(room)`, iterate `room.gracePeriodTimers` to cancel all outstanding timers, then reset `room.disconnectedAt = new Map()`.

M1 `sanitizePlayerName` only strips `<>`, not the full XSS character set **HIGH**

packages/server/src/handlers.ts:138

The function removes `<>` only. Characters like `"`, `'`, backtick, `&`, `\`, and `;` pass through. The incomplete sanitization gives false confidence and is a latent risk if names reach admin pages, raw SQL, or server-side rendering.

Recommendation: Either trust React's default escaping (remove all sanitization except the length cap) or allow only Unicode letters, spaces, hyphens, and apostrophes.

N7 Turn-timer seed uses `Date.now()` — millisecond precision **LOW**

packages/server/src/handlers.ts:1560

Two games starting in the same millisecond get identical seeds and identical shuffles. An attacker who knows the approximate server start time could predict the card deal.

Recommendation: Use a crypto-random seed: `Number(crypto.randomBytes(4).readUInt32BE())` rather than `Date.now()`.

N6 `viewFor` sends `capturePiles` asymmetrically across players **LOW**

packages/engine/src/view.ts

`PlayerView` exposes `capturePileCounts: Record<PlayerId, number>` for opponents but the own pile as a full card array. UI code must check two different fields for the same concept.

Recommendation: Add `capturePileCounts[you]` populated with `capturePile.length` so the record is complete for all players, and document the asymmetry in the type.

MISSING FEATURES & UX

Guards, Edge Cases & Interface Gaps

M3 `emitAck` has no timeout — promises can hang forever **HIGH**

`packages/web/src/net/socket.ts:179-187`

There is no `reject` path in `emitAck`. Every socket call in the app — `makeMove`, `startGame`, `leaveRoom` — uses this. On network drop or server crash, the promise never resolves and the UI displays a loading state that requires a page refresh to clear.

Recommendation: Add a timeout parameter (default 10,000 ms) and reject with a timeout error if the ack is not received. Socket.io 4.x supports native ack timeout via `socket.timeout(ms).emit(...)`.

M6 `pendingInvites` map is unbounded and module-global **MEDIUM**

`packages/server/src/handlers.ts:739`

There are no limits on how many invites a single player can send — they can spam invites to all other players. The map is module-level, survives room cleanup, and an attacker can hold many pending timers at any instant.

Recommendation: Cap outbound pending invites per player (e.g. 5). When the cap is exceeded, reject new invites with an explicit error.

N2 `generateRoomCode` retry loop silently throws on exhaustion **LOW**

`packages/server/src/handlers.ts:2487-2488`

After 100 failed attempts, an unhandled exception is thrown, so the socket event handler never sends an ack. The client's `createRoom` promise hangs forever (compounded by M3). The failure mode is completely silent.

Recommendation: Wrap `generateRoomCode()` in a try/catch in the handler and ack with `{ ok: false, error: 'SERVER_ERROR' }`.

N8 No rate limiting on `CREATE_ROOM` or `JOIN_ROOM` events **LOW**

`packages/server/src/handlers.ts`

A client can call `CREATE_ROOM` in a tight loop, creating thousands of rooms. `store.rooms` grows unboundedly, `broadcastRoomUpdate` iterates more rooms on each event, and cleanup timers accumulate.

Recommendation: Apply per-socket rate limiting to `CREATE_ROOM` and `JOIN_ROOM` (max 5 per minute per socket). Generalise the existing `MOVE_DEBOUNCE_MS` pattern into a per-event-type debounce map.

N10 `eventLog` in `GameProvider` not cleared on room leave **LOW**

`packages/web/src/state/GameProvider.tsx:258`

The event log resets only on component unmount. On room leave followed by an immediate join, the log retains up to 50 events from the previous game. Subscribers to `lastEvent` may see stale events momentarily.

Recommendation: Add `setEventLog([])` and `setLastEvent(null)` to the leave-room cleanup path alongside `setRoom(null)` and `setView(null)`.

Part2Board key includes **isCut** , causing card element remount on CUT event**LOW**

packages/web/src/components/Part2Board.tsx:117

When a CUT event arrives and **isCut** updates from **false** to **true** , the React key changes, causing unmount + remount. Framer Motion treats this as exit + entrance rather than an in-place transition.

Recommendation: Use a stable key (**cardId(play.card)** alone). Drive the cut animation via Framer Motion **variants** keyed on **isCut** so the element transitions in place.

PERFORMANCE**Memory, Compute & Bundle Efficiency****M4 Guest sessions in **store.sessions** are never pruned** **HIGH**

packages/server/src/store.ts

Every guest connection creates a session and the entry stays in **store.sessions** and **store.playerIndex** indefinitely — no expiry, no eviction, no prune job. Over hours of operation with many reconnecting or abandoned guests, the store grows without bound.

Recommendation: Add a TTL field to **SessionState** for guest sessions. Run a periodic prune every 10 minutes to remove sessions where **userId === null && socketId === null && ttl < Date.now()** with no associated room.

M5 **matchScoringForState called N+1 times per broadcast** **MEDIUM**

packages/server/src/handlers.ts:185-220

In the post-move broadcast loop, **matchScoringForState** is called once per player plus once for the ack — five identical invocations for four players. Each call walks the full event log and runs scoring math.

Recommendation: Compute **matchScoringForState** once before the broadcast loop and pass the cached result to each player's **transport.send** call and to the ack.

N3 Bundle size exceeds Vite's 500 KB warning threshold **LOW**

packages/web (build output)

Vite reports the JS chunk as 597 KB (171 KB gzipped). All screens — lobby, game, admin, profile — are loaded on the first page visit regardless of which route the user visits.

Recommendation: Add **build.rollupOptions.output.manualChunks** in **vite.config.ts** to split vendor libraries (**socket.io-client** , **framer-motion** , **react**), and use **React.lazy** + **Suspense** for non-critical screens.

package.json (dev dependency chain via drizzle-kit)

esbuild <= 0.24.2 (pulled in by @esbuild-kit/core-utils via drizzle-kit) allows any website to read from the esbuild dev server. Only affects npm run dev environments.

Recommendation: Upgrade drizzle-kit to 0.31.10 to pull in a fixed esbuild.

PRIORITISED ACTIONS

Top-10 Action List by Impact

The following actions are ordered by risk impact. Items 1-4 are exploitable in production today. Items 5-7 prevent silent failures and configuration crashes. Items 8-10 address memory, hardening, and UI correctness.

1 Fix admin secret open-by-default (C1)

Change isValidAdminSecret to return false when ADMIN_SECRET is unset. Log a startup warning. One missing env var currently gives any attacker full server admin.

Zero-line gameplay impact; highest-bang-for-buck security fix in the codebase.

2 Add voice relay room membership check (C2)

Before relaying VOICE_OFFER, VOICE_ANSWER, VOICE_ICE, and VOICE_RENEGOTIATE, verify both sockets share the same active room. Any authenticated player can currently send arbitrary WebRTC payloads to any other player in the system.

3 Upgrade drizzle-orm to fix SQL injection CVE (N4)

Run npm install drizzle-orm@^0.45.2 and follow with a drizzle-kit migration check. GHSA-gpj5-g38j-94v9 is high-severity and affects all DB-backed deployments.

4 Remove auth_token from OAuth redirect URL (C4)

The 30-day session token in the redirect URL is stored in browser history and proxy logs for every user who logs in via Google. Replace with SameSite=None; Secure cookies or a short-lived one-time code exchange.

5 Add emitAck timeout (M3)

Every UI action can hang forever on network failure. Use Socket.io 4.x native ack timeout: socket.timeout(10000).emit(...). One-liner fix with broad UX impact.

6 Validate card format and capture array length in

`isMakeMovePayload` (C5)

Add regex validation, cap `capture.length` at 13, and add a 4-character max string length check. Prevents large-payload DoS at the socket layer before reaching the engine.

7 Clamp admin `maxPlayers` to 4 to match engine constraint (C3)

Change the upper bound in `isValidPlayers` to `<= 4`. Prevents an admin from creating a configuration that causes `handleStartGame` to crash and leaves room state inconsistent.

8 Prune guest sessions from in-memory store (M4)

Add a TTL field to `SessionState` for guest sessions and run a periodic pruner every 10 minutes. Every unique visitor currently creates a permanent entry in `store.sessions`.

9 Add HTTP security headers (M10)

Add `helmet` middleware (or equivalent) before all route handlers. Minimum: `X-Frame-Options: DENY`, `X-Content-Type-Options: nosniff`, `Referrer-Policy: strict-origin-when-cross-origin`. Zero-cost for any production deployment.

10 Fix `Part2Board` stale `legalIds` / remove `eslint-disable` (M7)

Remove the `eslint-disable-next-line react-hooks/exhaustive-deps` comment and add `legalIds` and `play` to the `useEffect` dependency array. Current behaviour causes incorrect card highlights for one render after certain state changes.

→ Findings N5 (esbuild dev CVE) and N3 (bundle size) are lower-priority and can be addressed in a routine dependency maintenance pass. All 25 findings and their exact file locations are documented above.